

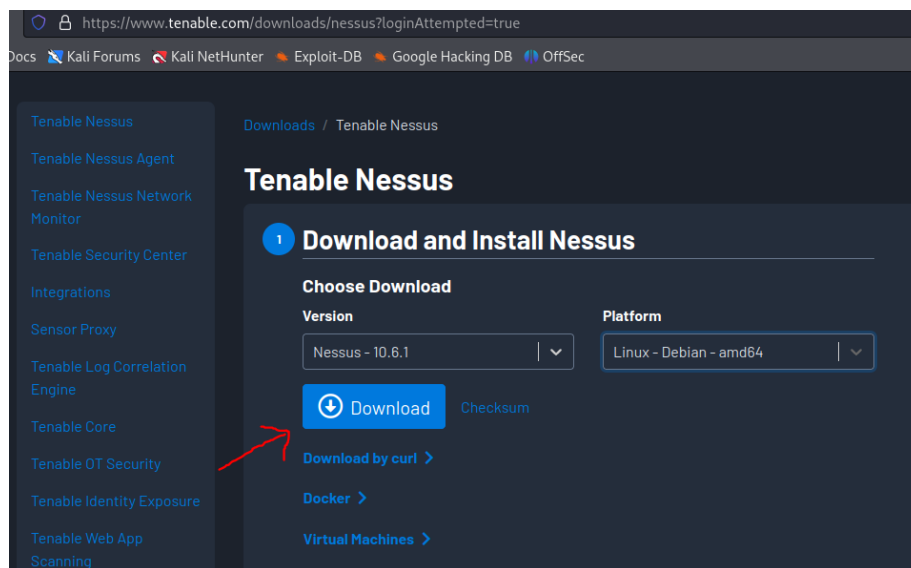
Nessus Installation Guide

After installing Kali Linux, follow these steps to download and install Nessus:

(Note - If your laptop can't comfortably run Nessus inside the Kali VM, install Nessus directly on your Windows machine — it's a standard Windows install and avoids VM disk and performance issues. One important note: if you plan to scan your Metasploitable VM from Windows, change the Metasploitable network from NAT to Host-only (or Bridged) so the host can reach the VM; with NAT the host cannot see the VM and Nessus won't be able to scan it. You can still use this guide on how to perform scans but I would recommend watching class recording for more info)

Download Nessus

- Open your web browser in Kali Linux.
- Go to this link: <https://www.tenable.com/downloads/nessus?loginAttempted=true>
- Select the current most updated version, which is Nessus 10.6.1. **(Currently it is 10.10.1)**
- For the 'platform,' choose "Linux Debian AMD64." Or Linux Ubuntu AMD64(Based on what platform you had selected at the time of installing Kali.
- Click the "**Download**" button.



The download will commence, and you can track its progress in your Kali Linux Downloads folder.

Nessus Installation:

For Nessus installation, follow these steps:

- Open the terminal in Kali Linux.
- Log in as the superuser (root) with the following command:

sudo su

- Navigate to the Downloads directory using the following command (replace 'meru' with your username):

cd /home/meru/Downloads

- Note: Be sure to use the correct case (uppercase 'Downloads').
- Install Nessus with this command (assuming the downloaded file is named 'Nessus-10.10.1-debian10_amd64.deb')

dpkg -i Nessus-10.10.1-debian10_amd64.deb

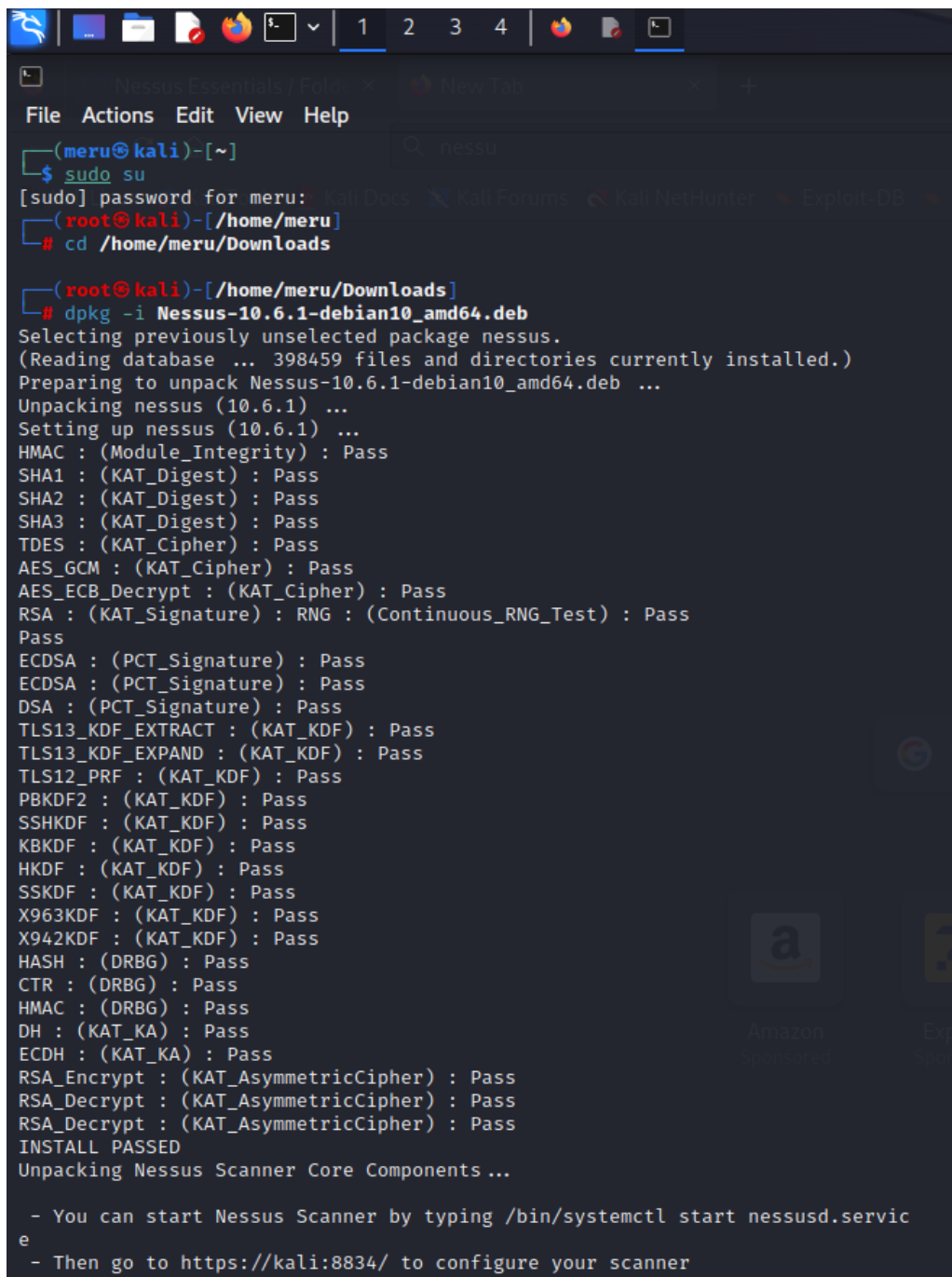
NOTE [If you had selected Ubuntu, you would change the command to:

dpkg -i Nessus-10.10.1-ubuntu1604_amd64.deb

[You can verify it with what version you have downloaded]

I am providing you with a screenshot of all the information I shared so far related to installation. If you encounter any issues or have questions during the installation, feel free to ask for assistance.

(Screenshots have older version of Nessus – Make changes according to the version you have downloaded and the platform you are using as mentioned earlier in the guide)



```
(meru@kali)-[~]
$ sudo su
[sudo] password for meru:
(meru@kali)-[/home/meru]
# cd /home/meru/Downloads

(meru@kali)-[/home/meru/Downloads]
# dpkg -i Nessus-10.6.1-debian10_amd64.deb
Selecting previously unselected package nessus.
(Reading database ... 398459 files and directories currently installed.)
Preparing to unpack Nessus-10.6.1-debian10_amd64.deb ...
Unpacking nessus (10.6.1) ...
Setting up nessus (10.6.1) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components ...

- You can start Nessus Scanner by typing /bin/systemctl start nessusd.servic
e
- Then go to https://kali:8834/ to configure your scanner
```

Start Nessus:

To start Nessus, please use the following command: (Every time you logout, and want to use Nessus again, you are to use this command first)

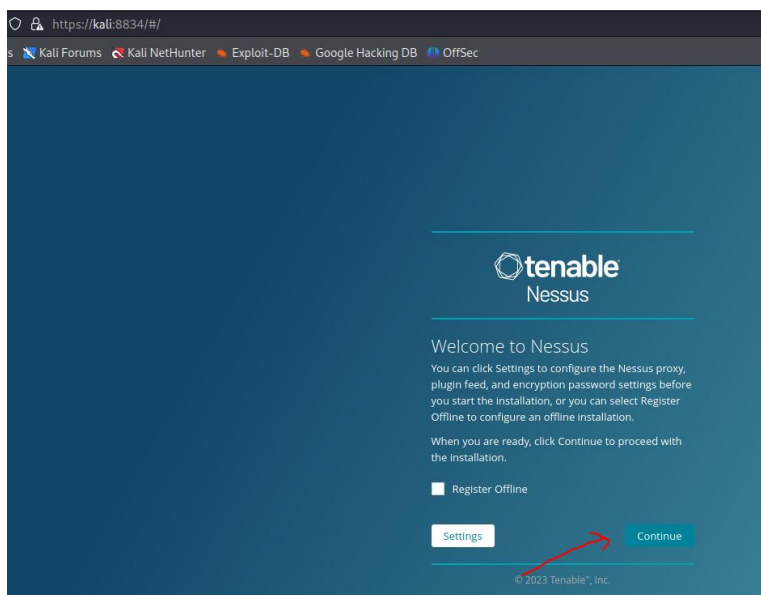
```
/bin/systemctl start nessusd.service
```

```
(root@kali)-[/home/meru/Downloads]
# /bin/systemctl start nessusd.service

(root@kali)-[/home/meru/Downloads]
#
```

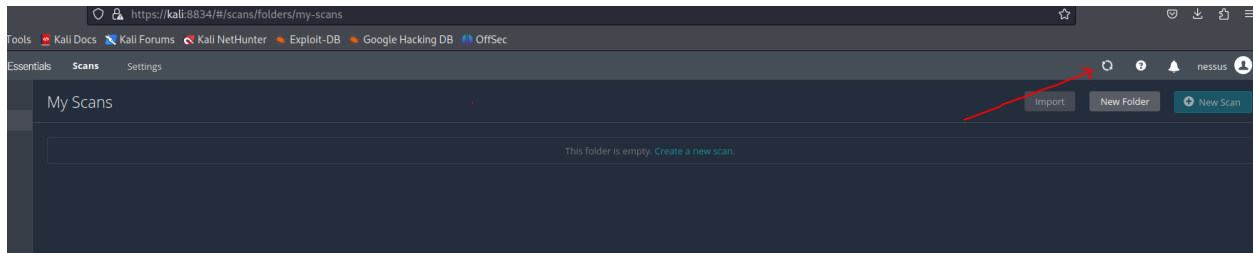
To access the Nessus web interface:

- Open your Firefox web browser within Kali Linux.
- Nessus should start automatically after the previous command. If it doesn't, manually enter the following URL in the address bar: `https://kali:8834`.
- When prompted, click on "Advanced."
- Accept the risk to proceed.
- Click "Continue" on the welcome to Nessus page.
- This will open the Nessus web interface for you to configure and use.



- On the next page, you'll be asked to select the Nessus option you would like to continue with. Because we are just using it for training purposes, we'll choose 'Register for Nessus Essentials' and click on Continue. (Nessus Essentials is available for free and lets you scan up to 16 Ips)
- The next page will ask you to register for it. Please enter your **first name**, **last name**, and school email address. Once done click on **Register**.
- You'll receive the activation code on the next screen. Make sure you copy it or take a screenshot of it.
- It will then ask you to create your user account. So please select a username and password of your choice and click on **Submit**. (You may want to note down the user account information you are entering)
- After this step you just need to wait for it to download and compile plugins. In the screenshot below you'll see that the arrow is marking the progress of the compilation of plugin. (This can

take an hour or two so please wait until it is done as we cannot start scanning before it is finished)

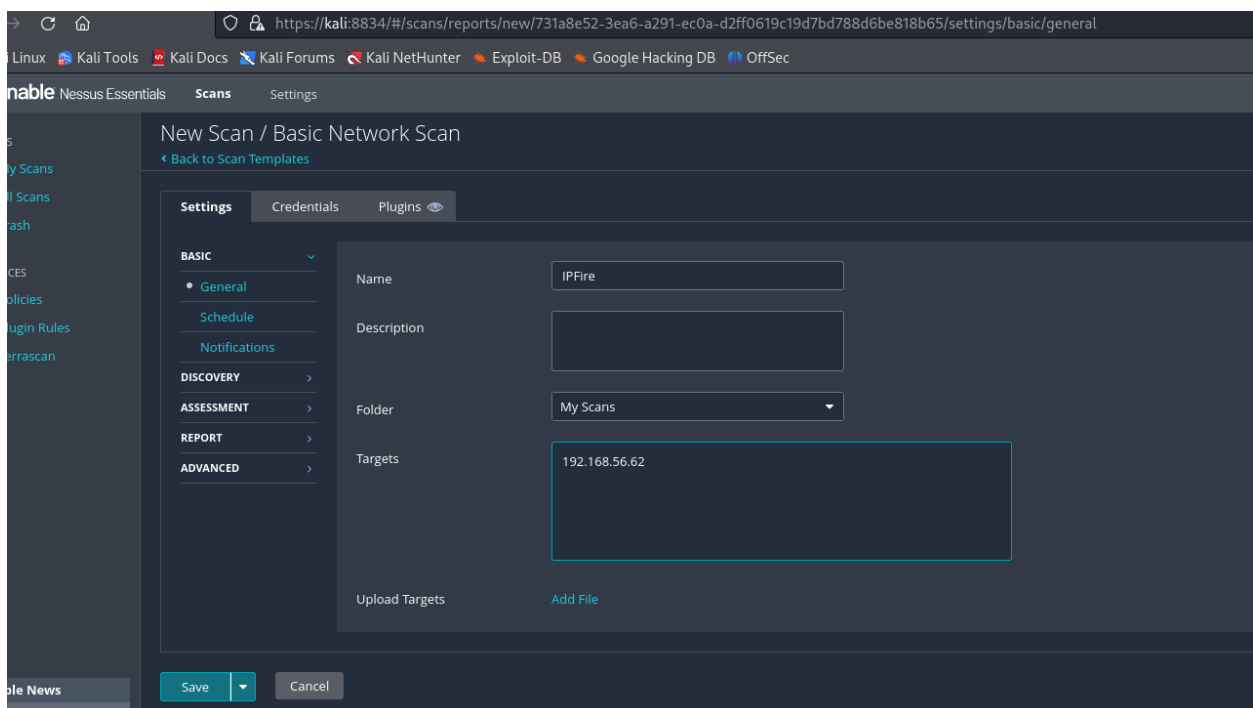


Congratulations! We are done with the installation. Now we can start scanning one of our virtual machines. I'll just share an example of an IPFire scan. (For this assignment, your task is to scan Metasploitable – I'll help you with the installation in class)

To scan Metasploitable, you'll just follow the same step as IPFire, except, you'll replace the name and IP address to Metasploitable.

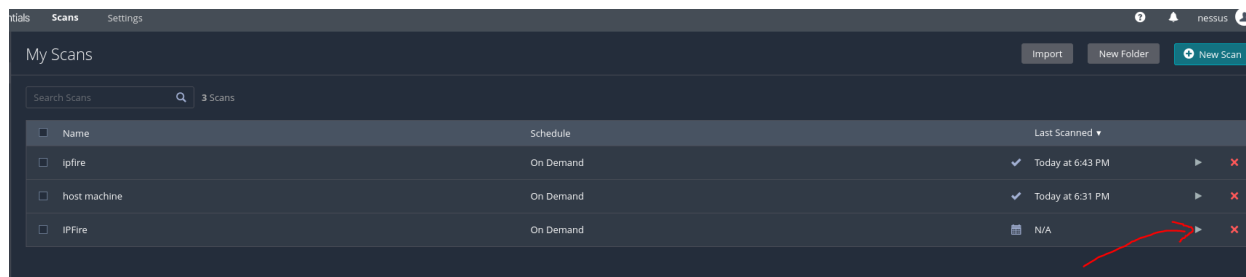
To begin scanning your IPFire machine using Nessus, follow these steps:

- Click on 'Create new Scan' or 'New Scan' located in the top right corner of the screen.
- Select 'Basic Network Scan' from the available options. (For this assignment, we'll focus on the basic network scan; however, I'll give you a brief info about other available scans in the class)
- Ensure that your IPFire machine is started and running before you initiate the scan.

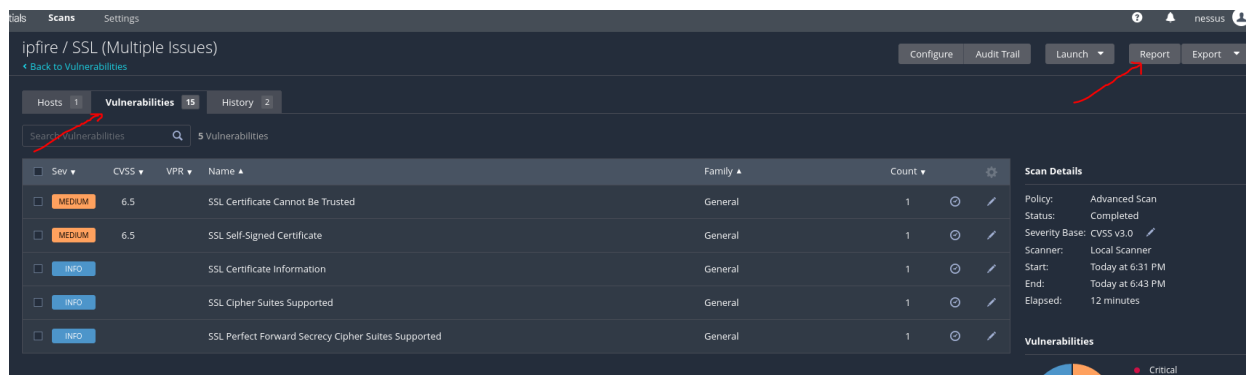


In the screenshot above, I have written 'IPFire' as the name and the target IP address in the 'Targets' section. Please use the IP that you had assigned to IP Fire. Once done click on **Save**.

You can now start your scan. (Screenshot is provided below)



It may take few minutes (Depends on the VM you are trying to scan) to finish the scan. After it is done, just click on the name you had written in the basic network scan. You will see the vulnerabilities there. You can go through those and generate a report too.

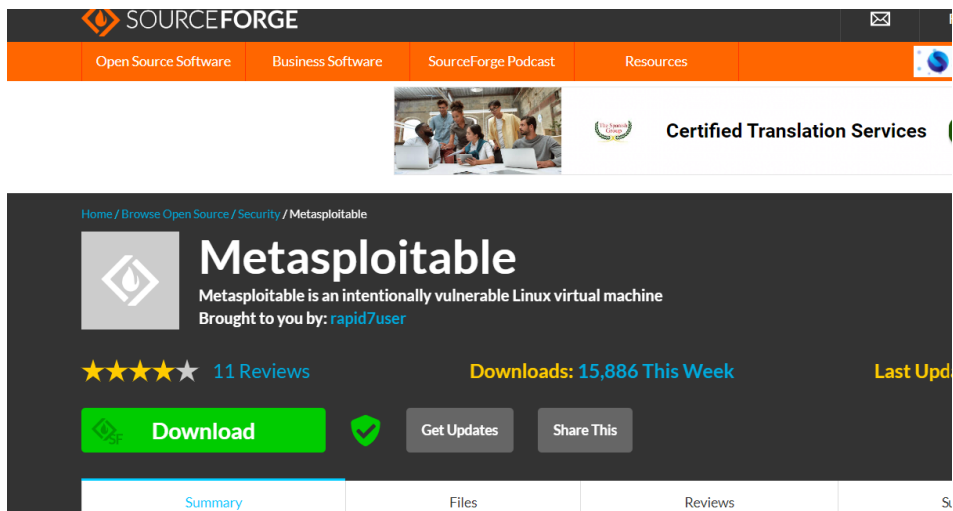


You are now done with the scan and its time for you to identify and prioritize the vulnerabilities. Research and think of what steps you're recommending to remedy the situation and which (if any) you would choose to accept.

Metasploitable Installation Guide

Step 1: Download Metasploitable

- Visit [this link](#) to download the Metasploitable file.

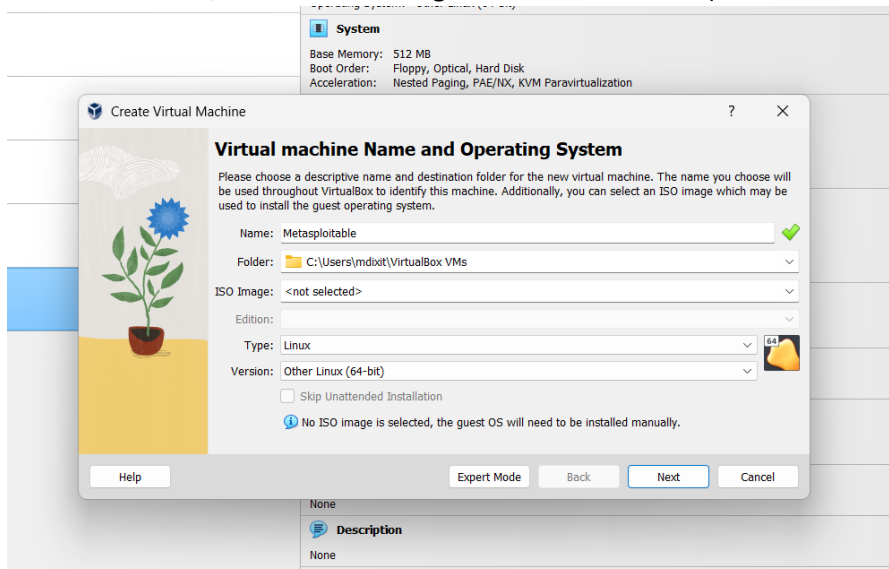


Step 2: Extract the Downloaded File

- Go to your Downloads folder and extract the zip file. You can keep the extracted contents in the same folder.

Step 3: Set Up Metasploitable in VirtualBox

- Open VirtualBox and add a new virtual machine.
- Note: If you're using an older version of VirtualBox, it might not support .vmdk files. In that case, leave the ISO image field blank for now. (Please see the screenshot)

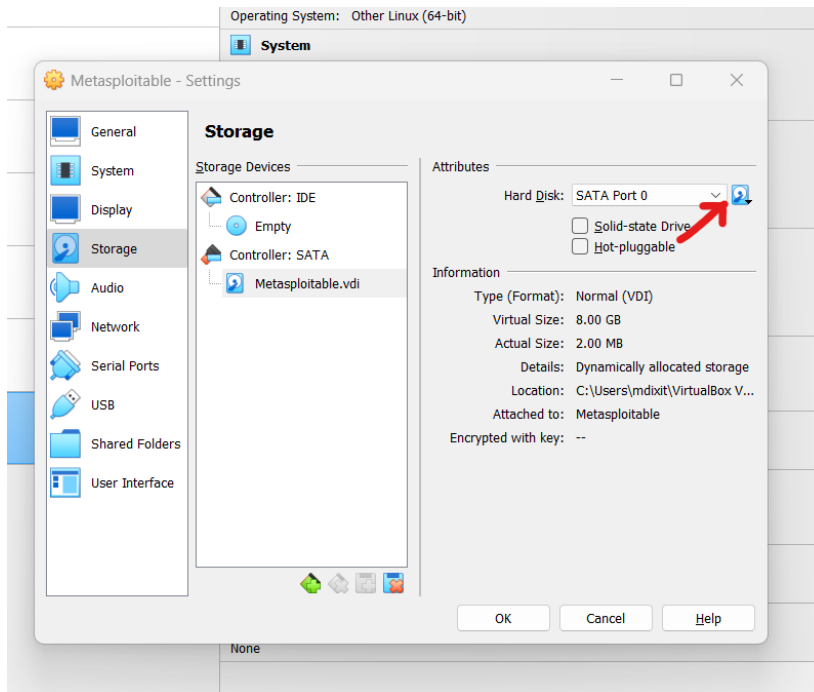


Step 4: Complete the Installation

- Proceed with the virtual machine setup, keeping all default settings

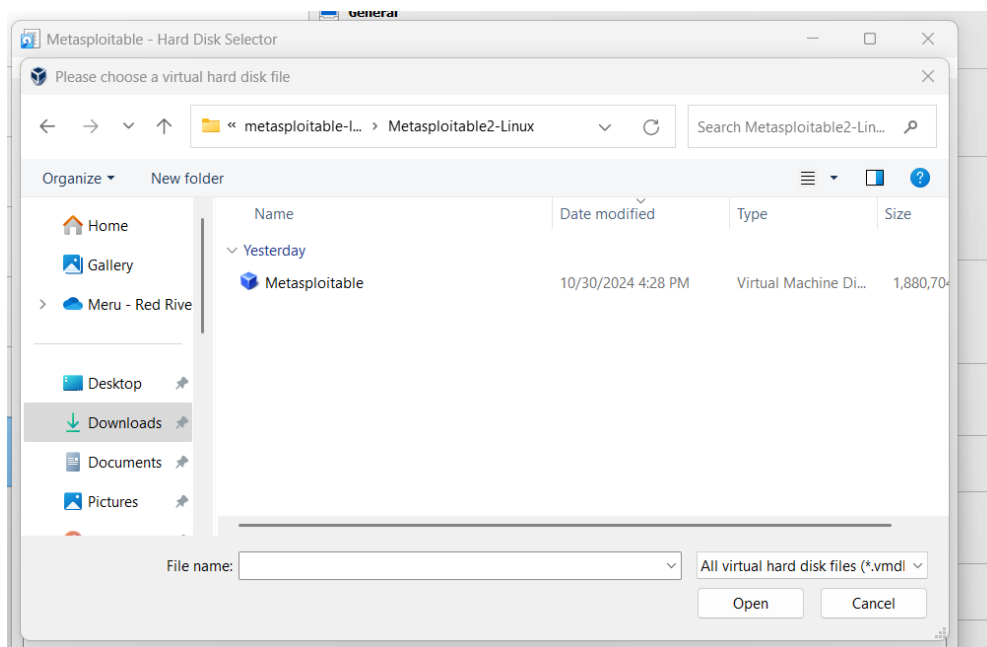
Step 5: Configure Storage Settings

- Right-click on your Metasploitable virtual machine and go to Settings > Storage.
- Click on the Metasploitable .vdi file, then press the blue icon in the top-right corner (refer to the provided screenshot if needed).



Step 6: Attach the Virtual Hard Disk

- Select 'Choose/Create a Virtual Hard Disk'.
- Click Add and select the extracted Metasploitable file from your Downloads folder.



Step 7: Start the Machine and Log In

Start the virtual machine. The login credentials will display on the screen.

- **User ID:** msfadmin
- **Password:** msfadmin

[Ensure the target machine (Metasploitable) is running before starting vulnerability scans]

If you plan to run Nessus on Windows, switch the Metasploitable VM from **NAT** to a **Host-only** (or **Bridged**) adapter first: power off the VM, open VirtualBox → Settings → Network, change Adapter 1 to **Host-only Adapter**, save, boot the VM, and use the VM's new host-only IP (e.g. 192.168.56.x) as your Nessus scan target.

Vulnerability Scan Report

- **Report by Afeez Lawal**
- **System Scanned - Metasploitable**
- **Vulnerability Scanning Tool used – (Nessus Vulnerability Scanner)**
- **Version of Scanner Used – Nessus 10.10.1**
- **Date of Scan – November 3, 2025**
- **Report Date – November 3, 2025**

Vulnerabilities Identified

Ruby REXML 3.3.3 < 3.4.2 DoS
Ruby Rack (Multiple Issues)
SSL Certificate cannot be Trusted

Rating: High
Rating: High
Rating: Mixed /High

(Repeat until all vulnerabilities are listed...) **For the assignment only first 3 will be assessed**

Description of Vulnerabilities

- **Ruby REXML 3.3.3 < 3.4.2 DoS Vulnerability** - A flaw in the Ruby REXML XML parser can be abused by giving it specially crafted XML files. This causes the system to use excessive resources and crash, resulting in a **Denial-of-Service (DoS)**. Updating to version **3.4.2 or later** fixes the issue.
Reference: <https://github.com/ruby/rexml/security/advisories/GHSA-c2f4-jgmc-q2r5>
- **Ruby Rack (Multiple Issues)** - Older Rack versions do not limit how much data they read into memory. Attackers can send very large requests to overload memory and crash the server (**DoS**), or manipulate headers to access information they shouldn't (**information disclosure**). Updating to **2.2.20 / 3.1.18 / 3.2.3 or later** resolves it.
Reference: <https://github.com/rack/rack/security>
- **SSL (Multiple Issues)** - The server uses SSL configurations that are not fully trusted or secure. Weak or improperly issued SSL certificates and outdated ciphers can expose users to **man-in-the-middle attacks**, certificate trust issues, or weak encryption.
Reference: <https://www.ssllabs.com/ssltest/>, <https://docs.tenable.com/nessus/>

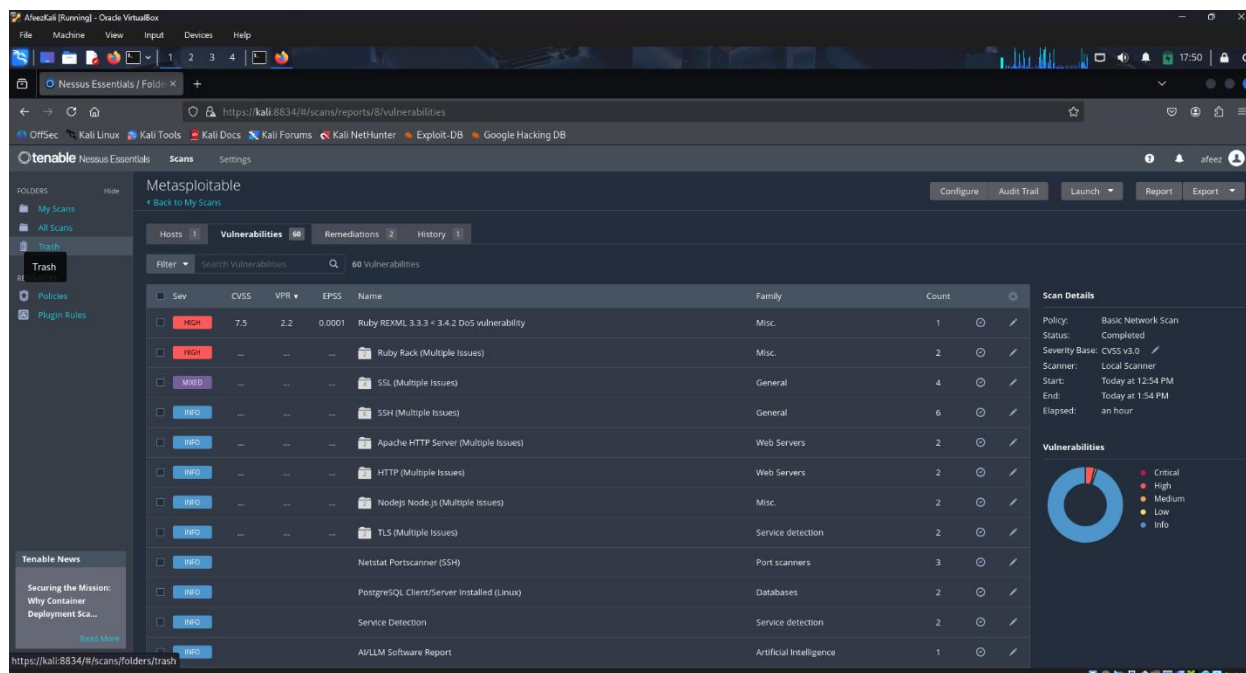
Criticality Assessment

A malicious attacker could exploit these vulnerabilities by sending specially crafted requests and data to overload system memory, manipulate traffic, or intercept encrypted communication. Ruby REXML and Rack flaws can be abused to crash the server by forcing it to process extremely large or malformed data, causing denial-of-service and potentially exposing internal resources through improper request handling. The SSL weaknesses could allow an attacker to impersonate the server, opening the door to man-in-the-middle attacks and unauthorized data access.

If exploited, these vulnerabilities could disrupt operations, expose confidential information, and damage data integrity. System outages would block legitimate users and harm business availability, while weakened encryption and improper request

handling could put customer data at risk. This exposes the organization to compliance and privacy risks, reputational harm, and potential financial loss,

Attachments



Suggested Fixes/Solutions

- Ruby REXML DoS Vulnerability**
*Fix: Update the REXML library to version **3.4.2 or later** to patch the XML parsing DoS flaw.*
example command: `gem update rexml`
Reference: <https://github.com/ruby/rexml/security/advisories/GHSA-c2f4-jgmc-q2r5>
- Ruby Rack (Multiple Vulnerabilities)**
*Fix: Upgrade Rack to the latest secure version (**2.2.20 / 3.1.18 / 3.2.3 or later**)*
example command: `gem update rack` `bundle update rack`
Reference: <https://github.com/rack/rack/security>
- SSL / Certificate Issues**
Fix:
 - **Replace untrusted/self-signed SSL certificates with trusted **CA-signed certificates****
 - *Ensure full certificate chain is installed*
 - *Remove weak ciphers and enforce strong TLS settings*

- *Enable TLS 1.2 or 1.3 only*

Steps

- *Generate CSR*
- *Get certificate from trusted CA*
- *Install chain bundle*
- *Restart web services*

Best practice config guides:

OpenSSL & TLS Hardening Guide - <https://ssl-config.mozilla.org/>

SSL Testing - <https://www.ssllabs.com/ssltest/>

Note: Supply information that will assist your audience in fixing a vulnerability, and if you can provide a description of a suggested fix - it will help to start patching efforts.

**After all, the key mission is to scan for vulnerabilities, identify, report, and then patch the vulnerabilities.*